

Policy_ID: CIP-ISP-001

Policy_Name: Information Security & Data Protection

Policy Version: 3.5

Effective_Date: 2025-11-01

Risk_Category: Security Applicable_Regulations: [ISO 27001, SOC 2, HIPAA]

Owner: Chief Information Security Officer (CISO)

Information Security & Data Protection Policy

1. Purpose & Scope [Risk Score: 1]

This policy establishes mandatory controls to protect corporate, customer, and partner data against unauthorized access, misuse, accidental disclosure, or loss. It applies to all employees, contractors, and third parties accessing Capstone systems.

2. Data Classification [Risk Score: 4]

Capstone applies a 4-tier classification system. Users must label all data accordingly:

1. **Public:** Safe for public release.
2. **Internal:** Operational info not for public distribution.
3. **Confidential:** Sensitive documents (Financial, HR).
4. **Restricted:** PII, Client Datasets, Regulated Data.

Non-Compliance Impact: Misclassifying "Restricted" data as "Public" is a **High Risk** violation leading to potential data leakage and disciplinary action.

3. Access Control [Risk Score: 5]

- **Least Privilege:** Access must be granted only on a need-to-know basis.
- **MFA:** Multi-Factor Authentication is **mandatory** for all privileged access.
- **Deprovisioning:** Terminated employees must have access revoked within **4 hours**.

Non-Compliance Impact: Sharing credentials or bypassing MFA is a **Critical Risk** (Score 5) resulting in immediate access revocation and potential termination.

4. Encryption Standards [Risk Score: 5]

- **At Rest:** All databases, backups, and laptops must use **AES-256**.
- **In Transit:** All web traffic and API calls must use **TLS 1.2+**.

Non-Compliance Impact: Storage of unencrypted sensitive data is strictly prohibited. Violations constitute a **Critical Security Incident**.

5. Endpoint & Network Security [Risk Score: 4]

- **EDR Agent:** Mandatory on all laptops/servers. Disabling EDR triggers automatic lockdown.
- **Zero-Trust:** Internal networks must be segmented. No direct RDP/SSH without VPN.
- **Patching:** Critical patches must be applied within **72 hours**.

Non-Compliance Impact: Connecting a non-compliant device to the corporate network is a **High Risk** violation.

6. Incident Response [Risk Score: 5]

Employees must report incidents to security@capstone.inc within **30 minutes** of detection.

- **Financial Impact Awareness:** Downtime costs ~\$8,000/hour. Regulatory fines can exceed \$250k.

Non-Compliance Impact: Failure to report a known security incident is a **Critical Risk** and grounds for immediate termination.

7. Third-Party Management [Risk Score: 4]

- All vendors must sign a **Data Processing Addendum (DPA)**.
- Critical vendors must undergo annual security audits (ISO 27001/SOC 2).

Non-Compliance Impact: Onboarding a vendor without a DPA is a **High Risk** procurement violation.